

Painel de KRI com Limiares

INDICADOR DE RISCO EXISTE PARA DISPARAR AÇÃO ANTES DO INCIDENTE · SEM LIMIAR, O NÚMERO É SÓ UM NÚMERO

Da Norma à Liderança

O método do Empilhamento · Instrumento 8
André Augusto Azarias de Souza

Organização: Período apurado: Apurado por: Apresentado ao fórum em:

Indicador	Verde	Âmbar	Vermelho	Fonte (quem reproduz o número)	Medido
Ativos críticos com correção no prazo	95% ou mais	85% a 94%	Abaixo de 85%	Gestão de vulnerabilidades, cruzada com o inventário	
Tempo médio de detecção	Até 24 horas	24 a 72 horas	Acima de 72 horas	Registro de incidentes, campo de primeira detecção	
Acessos privilegiados com autenticação resistente a phishing	100%	90% a 99%	Abaixo de 90%	Provedor de identidade, por grupo privilegiado	
Exceções vencidas em aberto	Zero	1 a 3	Acima de 3	Registro central de exceções (instrumento 4)	
Fornecedores críticos com avaliação vigente	95% ou mais	80% a 94%	Abaixo de 80%	Inventário de terceiros, com data da avaliação	
Sistemas críticos com restauração testada no semestre	100%	90% a 99%	Abaixo de 90%	Atas dos testes de restauração	
Revisão de acessos concluída no ciclo	100%	1 ciclo em atraso	Mais de 1 ciclo	Registro do processo de revisão	
Recursos em produção fora do padrão declarado (drift)	Zero	1% a 5%	Acima de 5%	Varredura do estado real contra o repositório de infraestrutura como código	

O que cada cor aciona (declare junto com o painel): ● **âmbar** exige plano com prazo no próximo fórum; ● **vermelho** exige comunicação imediata ao diretor responsável.

O erro mais comum: indicador sem limiar, que não dispara nada e só ocupa espaço no slide. O irmão gêmeo é o indicador que ninguém consegue apurar, que depende de um dado que nenhum sistema produz ou de três dias de trabalho manual por mês: sobrevive dois trimestres e some. Antes de aprovar um KRI, apure-o uma vez à mão: se doer, não vai durar.